

1. Tạo bucket và cấu hình ban đầu

- Tạo bucket (Console / AWS CLI):
 - Console: S3 → Create bucket → đặt tên toàn cầu duy nhất (ví dụ booking-app-assets), chọn Region.
 - CLI: `aws s3 mb s3://booking-app-assets --region ap-southeast-1`.
- Quyết định Region: chọn gần user chính để giảm độ trễ; lưu ý chi phí và compliance.
- Cấu hình cơ bản khi tạo: versioning (Enable nếu cần bảo vệ overwrite), default encryption (SSE-S3 hoặc SSE-KMS), block public access (mặc định bật; tắt cho static website khi cần) và object lock nếu cần tuân thủ.
- Tags & bucket policy: thêm tags cho quản lý chi phí; bucket policy dùng JSON để cấp quyền truy cập (ví dụ: chỉ cho CloudFront đọc) hoặc limit theo VPC endpoint.

2. Quyền truy cập, IAM và bảo mật

- S3 access control options:
 - Block Public Access (global và bucket level) — bật để tránh lộ dữ liệu trừ khi bạn chủ ý public.
 - Bucket policy — chính sách chi tiết (ví dụ cho phép chỉ CloudFront GET).
 - IAM policies — gán role/user với quyền `s3:GetObject`, `s3:PutObject`, `s3:ListBucket` theo principle of least privilege.
 - ACLs thường không dùng nếu bạn dùng bucket policies và IAM.
- Encryption: bật server-side encryption: SSE-S3 (AWS-managed), SSE-KMS (KMS key, audit & key control) hoặc client-side encryption nếu cần.
- VPC Endpoint: dùng Gateway VPC Endpoint (`com.amazonaws.<region>.s3`) để lưu traffic giữa VPC và S3 trong mạng AWS, tránh public internet.
- Logging & Audit: bật S3 server access logs hoặc use CloudTrail Data Events để audit access to objects.

3. Upload / download / quản lý dữ liệu (CLI, SDK, presigned)

- AWS CLI cơ bản:
 - Upload file: `aws s3 cp ./local.jpg s3://booking-app-assets/images/local.jpg`
 - Sync folder: `aws s3 sync ./dist s3://booking-app-assets/website --delete`

- Download: `aws s3 cp s3://booking-app-assets/path/file.png ./`
- Presigned URLs (khi cần cấp quyền tạm thời cho client upload/download):
 - Backend tạo presigned URL (SDK): ví dụ SDK cho Node.js tạo presigned PUT để client upload trực tiếp lên S3.
- SDK usage: S3 client có sẵn cho JavaScript (aws-sdk v3), Python (boto3), Java... dùng để list, get, put object programmatically.
- Multipart upload: dùng cho file lớn (>100MB) để tăng tốc và cho phép resume khi gián đoạn.

4. Hosting static website & tích hợp CloudFront

- Static website trên S3: bật “Static website hosting” ở bucket (index document, error document); bucket phải public hoặc dùng CloudFront origin access để giữ bucket private. Thông thường production dùng CloudFront với origin access để bảo mật và dùng HTTPS/CNAME/custom domain. Hướng dẫn deploy static site + CloudFront + HTTPS là pattern phổ biến để tối ưu performance và bảo mật.
- Quy trình cơ bản: upload build → invalidate CloudFront path khi cần → CloudFront phân phối trên edge locations.
- Certificate: dùng AWS Certificate Manager (ACM) để cấp SSL cho CloudFront (chỉ ở region us-east-1 cho CloudFront).
- Cache headers: set proper Cache-Control và Content-Type metadata khi upload để tối ưu cache và đúng render trên client.

5. Lifecycle, versioning và cost optimization

- Versioning: bật để tránh mất dữ liệu do xóa/ghi đè; kết hợp với lifecycle rules để purging older versions theo retention policy.
- Lifecycle rules: tự động chuyển object từ S3 Standard → S3 Intelligent-Tiering / Standard-IA → Glacier theo chính sách (ví dụ: chuyển sang IA sau 30 ngày, Glacier sau 180 ngày).
- Expiration & cleanup: dùng lifecycle để xóa artifacts tạm thời (build preview, review app assets) sau N ngày.
- Storage Class: chọn class phù hợp: Standard cho hot data; Standard-IA/One Zone-IA cho ít truy cập; Glacier/Deep Archive cho backup lâu dài.

- Cost tips: bật S3 analytics để tối ưu lifecycle; hạn chế request (GET/PUT) không cần thiết; enable compression for assets (gzip/brotli) before upload.

6. Monitoring, logging, và bảo trì vận hành

- Access logs: bật S3 Server Access Logs hoặc CloudTrail data events để audit object-level access (kiểm tra ai đã GET/PUT).
- Metrics & alarms: CloudWatch metrics (BucketSizeBytes, NumberOfObjects) và tạo alarm khi dung lượng vượt ngưỡng hoặc request rate tăng đột biến.
- Inventory & Analytics: bật S3 Inventory để lấy list objects theo schedule; S3 Storage Lens để phân tích usage và recommend tối ưu.
- Backup & replication: nếu cần DR/multi-region, dùng Cross-Region Replication (CRR) hoặc Same-Region Replication (SRR); thiết lập IAM role cho replication.

7. Ví dụ workflow & lệnh thường dùng

- Tạo bucket (CLI): `aws s3api create-bucket --bucket booking-app-assets --region ap-southeast-1 --create-bucket-configuration LocationConstraint=ap-southeast-1`
- Bật versioning: `aws s3api put-bucket-versioning --bucket booking-app-assets --versioning-configuration Status=Enabled`
- Bật encryption SSE-KMS: `aws s3api put-bucket-encryption --bucket booking-app-assets --server-side-encryption-configuration '{"Rules":[{"ApplyServerSideEncryptionByDefault":{"SSEAlgorithm":"aws:kms","KMSMasterKeyID":"arn:aws:kms:....:key/..."}}]}'`
- Sync static site (CI job): `aws s3 sync ./dist s3://booking-app-assets --delete --cache-control "max-age=31536000,public" --acl public-read` (lưu ý: production nên dùng CloudFront + OAC thay vì public-read trực tiếp)
- Tạo presigned URL (Node.js, aws-sdk v3):
 - Sử dụng `S3RequestPresigner` để generate PUT URL với expiry.

8. Best practices tóm tắt

- Principle of least privilege cho IAM; tránh public buckets trừ khi cần.
- Dùng CloudFront + Origin Access/Origin Access Identity (OAI) hoặc Origin Access Control (OAC) thay vì làm bucket public.
- Bật encryption và logging; sử dụng KMS nếu cần kiểm soát key.

- Sử dụng lifecycle để tối ưu chi phí; scan objects để phát hiện dữ liệu nhạy cảm.
- Lưu templates deployment (CloudFormation / Terraform) trong repo để reproducible infra.
- Test presigned & multipart workflows trên staging trước production.